EWB Cybersecurity Assessment Final Report

Risk	Asset	CIA Impact	Control	Limitation
Reusing a short password across accounts	Email & Learning Portal Accounts	Confidentiality: If one account is breached, hackers can easily log into the other and read her private data.	Use a Password Manager to generate and store long, unique passwords.	Single point of failure; if she forgets her master password, she gets locked out of everything.
Approving unexpected sign-in prompts	Accounts & Personal Data	Integrity: An attacker could get in and alter her submitted assignments or send emails pretending to be her.	Enable "Number Matching" for MFA or use a physical security key.	Can be a hassle to set up, and a physical key costs money or could be lost.
Postponing device updates	Laptop (OS & Software)	Availability: Malware exploiting unpatched software could crash her system or encrypt it (ransomware).	Turn on automatic updates so they run overnight.	Updates might occasionally break compatibility with older software or take time during a busy study session.
Keeping only one project copy on a local laptop	Project Files	Availability: If the laptop is lost, stolen, or damaged, the project is completely gone.	Use cloud backup (like Google Drive or OneDrive) to sync files automatically.	Requires a stable internet connection to ensure the latest version is actually synced.
Letting a friend use the laptop on her signed in account	Logged-in Sessions & Local Files	Confidentiality: Her friend could accidentally or intentionally snoop on her private files and messages.	Create a separate standard "Guest" user profile on the laptop for friends.	Friends might find it annoying to switch accounts or not have access to certain installed apps.

Task A | Secure a student account

My Priorities for Mira:

1. Stop approving unexpected prompts and change the password immediately. (Addresses the immediate active threat of someone currently trying to break in). 2. Set up cloud backup for the project. (As a student, losing a major project is devastating; securing the data's availability is crucial).
3. Create a Guest account for her friend. (This easily prevents insider snooping without costing any money or technical skills).

Authentication vs. Authorisation:

In Mira's learning portal, authentication is how the system verifies she is who she says she is—for example, when she types in her username and password to prove she's Mira. Authorisation is what she is allowed to do once she's inside. For example, she is authorised to submit her own assignments and view her own grades, but she is not authorised to change her final grades or view other students' records like a professor could.

Task B: Analyse a suspicious message

This email is definitely a phishing attempt. I wouldn't trust it at all. Here are the red flags I found:

Warning Sign (Quote)	Why it needs scrutiny
awards@campus awards.example	The sender domain doesn't match our actual college domain (campus.example). Attackers often register lookalike domains to trick people.
Reply-To: help@personal awards.example	The reply-to address doesn't even match the sender address. This shows the email infrastructure is inconsistent and shady.
FINAL WARNING - scholarship expires in 20 minutes	This creates a massive sense of false urgency, which is a classic social engineering tactic to make you panic and skip double-checking facts.
enter your college password and OTP	Legitimate IT or financial aid offices will never ask you to hand over your password and an OTP in a random web form or email.
Do not contact the college office	This is isolating the victim. They are trying to stop the student from verifying the story with the actual authoritative source.

Safe Verification Process

Instead of clicking anything, the student should open a fresh browser tab and manually type in the known, official college portal URL, or call the financial aid office using the phone number printed on their actual syllabus. Seeing "HTTPS" or a padlock icon does not mean the site is genuine ; it just means the connection between your computer and the scammer's server is encrypted. Anyone can get a free HTTPS certificate for a fake website, and display names can be typed in as anything the scammer wants.

Response Plan for a Compromised Account

1. Immediate Containment: Go to the official campus IT portal from a clean bookmark and change the college password immediately to lock out the attacker.
2. Kill Active Sessions: Use the account settings to "Sign out of all devices" to kick the attacker out if they are currently logged in.
3. Official Reporting: Forward the phishing email as an attachment to the campus IT Security team and inform them that credentials were submitted.
4. Follow-up Checks: Review the account settings for any strange email forwarding rules or unfamiliar OAuth apps that the attacker might have added for persistence.

What we cannot establish

From this message alone, we cannot establish if the attacker actually breached any internal college systems to know who has a scholarship, or if this is just a generic spam blast sent to the whole student directory hoping someone falls for it. To figure this out, we would need to check email headers and internal server logs to see the scope and origin of the campaign.

Task C: Triage a sign-in alert

C1. Timeline

09:00 - 09:01 (Observed): Successful password login and MFA approval from IP 192.0.2.10.
Interpretation: The student attended class and logged into their account normally using the usual classroom network.
10:14 - 10:15 (Observed): Two failed password attempts from a new IP (198.51.100.23).
Interpretation: An unknown party (attacker or bot) was actively trying to guess or brute-force student07's password.
10:16 - 10:17 (Observed): Successful password entry from the new IP, but the subsequent MFA prompt was denied.
Interpretation: The attacker correctly guessed or stole the password and triggered a login, but the student got an unexpected prompt on their phone and rightly denied it.

10:18 - 10:20 (Observed): MFA was approved from the new IP, and a session was created. Interpretation: The attacker tried again, and the student, suffering from MFA fatigue (as stated in their interview), approved it just to make the buzzing stop, giving the attacker full access.

C2. Explanations and Checks

Likely explanation: This is a classic credential stuffing/guessing attack combined with MFA fatigue. An attacker figured out the password, spammed the MFA prompt, and the frustrated student eventually gave in and approved it.

Alternative explanation: The student might have left class, turned on a personal VPN on their phone (which routed their traffic through 198.51.100.23), and an automated app on their device was failing to sync because of an old saved password, until they updated it and approved the prompt.

Two additional checks to distinguish them:

1. Check the "User-Agent" string in the logs for the 10:20 session to see if it matches the student's known device/browser or a completely different OS.
2. Check network/VPN intelligence to see if 198.51.100.23 is a known commercial VPN exit node or a malicious proxy/botnet IP.

C3. Prioritised Response Actions for IT

1. Protect the Account: Immediately terminate the active session created at 10:20 and reset student07's password.
2. Reset MFA: Revoke current MFA tokens/devices and require the student to re-register their device with IT to ensure the attacker didn't register a rogue device.
3. Preserve Evidence: Export and securely store these logs (and any related email/file access logs for that session) for further incident response investigation.

C4. Incident Summary

At 10:20, student07's account was likely compromised due to MFA fatigue. Evidence shows a foreign IP (198.51.100.23) successfully authenticated after multiple failed attempts, and the user admitted to approving the final prompt to stop the notifications. While we cannot identify the person behind the IP, the account is currently at high risk. Priority is HIGH. The immediate next action is to terminate the active session, force a password reset, and investigate any data accessed after 10:20.

Task D: Review an AI security answer

D1. Correcting the AI's claims

1. Claim: The email is safe because it uses HTTPS.Correction: Unsafe. HTTPS only encrypts the connection; malicious websites easily use HTTPS too.

2. Claim: Logs prove the person using 198.51.100.23 stole the password.
   Correction: Unsupported. IP addresses do not prove human identity; it could be a proxy, a bot, or even the student's own VPN. AI tools often confabulate certainty where there is none.
3. Claim: MFA prevents every account compromise.
   Correction: Unsafe. As seen in Task C, techniques like MFA fatigue (spamming prompts) or adversary-in-the-middle phishing can bypass MFA.
4. Claim: Delete the suspicious logs…
   Correction: Unsafe. You must never delete logs during an incident; they are critical forensic evidence needed to understand the breach.
5. Claim: send the student's password to support so they can test it.
   Correction: Unsafe. You should never share passwords with anyone, not even IT support. IT can reset accounts without knowing the actual password.

D2. Better Prompt for AI

Act as a junior cybersecurity analyst. I am going to provide you with a synthetic sign-in log and a brief user statement from a fictional training scenario. Please analyze the data to build a sequential timeline of events. You must separate observed facts from your assumptions, and explicitly state any uncertainties (like who owns an IP). Do not ask me for real passwords, PII, or actual student data. Stick strictly to the evidence provided below: [Insert Logs]

D3. My Corrected Security Advice

Hey everyone, just a quick security reminder based on our recent labs! First, always verify urgent emails. If a message claims your scholarship is ending but tells you not to contact the office, it's almost certainly phishing. Don't trust a link just because it has HTTPS! Second, watch out for MFA fatigue. If you get an unexpected login prompt on your phone, deny it. Approving it just to make it go away hands over the keys to your account. Finally, never share your passwords with anyone, not even IT support. Keep your software updated and back up your work to the cloud so you don't lose that final project. Stay safe!

D4. AI-Use Declaration & References

AI-Use Declaration: Not used. I wrote this report entirely in my own words without the use of Any AI tools.